

AI Governance Guide



© 2026 David Mauro | NetGain Technologies | Cyber Crime Junkies Media | Moving Target Book Series

[David Dean Mauro](#) | [NetGainIT.com](#) | [CyberCrimeJunkies.com](#) | [Moving Target Book Series](#) | [Complimentary AI Workshop](#) & [Cyber Awareness Lunch & Learn](#) — inquire at [NetGainIT.com](#)

AI GOVERNANCE GUIDE

Personal AI at Work · AI Readiness · Adoption Model · Tool Matrix · Governance Checklist

David Dean Mauro | NetGainIT.com | CyberCrimeJunkies.com | Moving Target Book Series

1. AI Readiness Checklist for Leaders

Readiness and Risk There are three (3) new levels of risk with AI. At the **Prompt level** (insider risk what employees upload and how they use AI. At the **App Level**. Lack of Access Control (based on what systems AI gets connected to). **Agentic Level**. Acts automatically without humans in the loop. *Assumes user Identity and you are liable for the actions as if user performed them. Each type of prior risks compound (Prompt level and App level).*

Use these questions to develop your readiness.

Level 1 — Prompt and Insider Risk

- ☐ **Have you surveyed your employees on which AI tools they actually use?**
- ☐ **Do you have a written AI policy, and when was it written?**
- ☐ **Does it address sharing or exporting chats?**

Shared links, exported transcripts, screenshots pasted into a team channel. A shared chat link can outlive the account it came from. An SMB AI governance policy should explicitly prohibit employees from creating or publishing public share links to AI conversations when those conversations contain company information, business analysis, customer information, internal decisions, proprietary material, or anything that could become relevant to a dispute. Separate FYI: the underlying AI conversation may still become relevant evidence in litigation.

- ☐ **Does it cover personal devices and cell phones?**
- ☐ **Does it name the data that may never go into a prompt, specifically enough that a new hire could apply it?**

Where is the data located that you want to use with AI? Who can access it? Have you classified your data in any way (Public, Confidential-Classified, Internal-only, etc.)?

Level 2 — Application, Architecture, and Physical Controls

- ☐ **Which AI applications are approved, at what license tier, and who approved each one?**
- ☐ **Does any AI tool connect to your file storage, email, CRM, or ERP? Which ones, and under whose credentials?**
- ☐ **How are you managing Agent Identities?**
- ☐ **Where does that data physically sit, and under whose contract?**
- ☐ **Can you produce a log of who used what, last month?**
- ☐ **An employee resigns on Friday. What happens to their AI accounts, prompts, doc's uploaded and the contents of them?**

Level 3 —Agents & Workflows

- ☐ Is anyone building workflows or agents right now? Do you know that for certain? What are they building?
- ☐ What credentials would an agent run under, and what could it reach with them?
- ☐ Who reviews output before it reaches a customer or leaves the building?
- ☐ What is your kill switch? Who pulls it, and how fast?
- ☐ When a vendor changes its model or its terms, who notices?

2. How We Think About AI Adoption

Crawl (Pilot)	Walk	Run
• High Impact-Low Complexity • Proven ROI • Narrow Scope • Governance Model Built Around Pilot	• Fundamentally similar but more complex • Wider Scope (not yet companywide) • Governance Finalized Companywide	• High impact specialized implementation • Advanced • Often Agentic or Expanded Workflows • Companywide

The Goal: Build a Trusted & Evolving Process Tracked to P & L

3. The Tool Matrix

Personal & Consumer Accounts

	ChatGPT Free/Go/Plus/Pro	Claude Free/Pro/Max	Copilot personal	Hatz AI
Governing contract	Consumer terms	Consumer terms	Consumer terms	Business agreement
Trains on your data	Yes, opt-out	Yes, opt-out	Consumer terms differ from tenant	No
Retention*	30 days after deletion	30 days, or 5 years if training allowed	Per consumer terms	Per your agreement
DPA in place	None	None	None	Yes, via provider
Admin sees who used what	No	No	No	Yes
Admin enforces settings	No	No	No	Yes
Can you prove your settings**	No	No	No	Yes
Survives employee leaving	Goes with them	Goes with them	Goes with them	No
Fit for confidential work	No	No	No	Yes

Retention:** Though the LLM is not trained on data, third-party access can exist for a lengthy time, violating NDAs, customer agreements, and audit controls. Subscription Tier decides almost everything. AI Brand decides almost nothing. *Prove Settings:** When audited, cyber insurance policy application and compliance requires you can prove through logs.

Business Tiers (Enterprise levels, Not Consumer)

	ChatGPT Business/Ent	Claude Team/Ent/API	M365 Copilot licensed	Hatz AI
Trains on your data	No	No	No	No
Retention*	Up to 30 days abuse monitoring	7 to 30 days by config	In tenant, your policy	Near-zero upstream
Fit for confidential work	Yes	Yes	Yes	Yes
Where data sits	Vendor infra	Vendor infra	Your M365 boundary	AWS US, org-separated
Prove your settings?	Yes	Yes	Yes, native Purview	Yes
Control after employee leaves?	Yes	Yes	Yes	Yes
You manage / set up	SharePoint + classification is yours, user tracking yours	Config is yours, data classification, user tracking yours	SharePoint, data classification, user tracking yours, developer often needed	Provider-managed, no developer needed

Retention:** Though the LLM is not trained on data, third-party access can exist for a lengthy time, violating NDAs, customer agreements, and audit controls. Subscription Tier decides almost everything. AI Brand decides almost nothing. *Prove Settings:** When audited, cyber insurance policy application and compliance requires you can prove through logs.

Copilot: the tool is safer, but you own and will need people for SharePoint setup, data classification, and user tracking.

SOC 2, ISO 27001, HIPAA

	SOC 2	ISO 27001	HIPAA BAA, CMMC
Anthropic (Claude), commercial	Type I & II	27001:2022 + 42001:2023 AI	Enterprise only (activated by admin). Not Free/Pro/Max/Team
OpenAI (ChatGPT), commercial	Type 2	27001:2022 (Enterprise)	Enterprise/Edu + API. Not on Business
Microsoft 365 Copilot	Inherits M365 stack	Inherits M365 stack	Standard BAA for covered services
Hatz AI	Type II, under NDA	Yes	SOC 2 and ISO: Yes. Not yet HIPAA. May qualify with CMMC depending on segmentation

4. Most Common Governance Gaps

These are the main gaps found in most small-mid organizations today in re: AI Governance.

Gaps	Increased Risks
No Current AI Inventory	Shadow AI. Compliance, breach, and legal risks skyrocket.
Data Lineage	Undocumented, unapproved training data.
Data Integrity	Lack of Data Classification. Garbage in. Overconfident garbage out.
Data Security	Sensitive data exposed without logging, encryption, or filter blocking.
Access Control	No role-based permissions. High risk.
Human Oversight	Autopilot without human-in-the-loop.
Compliance Tracking	Vendor compliance does not equal your compliance.
Audit Logging — Eyes on Glass	Blind usage without ability to determine IP loss or cause.

5. Your AI Governance Checklist

This checklist will not make you invincible. Nothing will. Governance unlocks creativity. It will move you out of the way and become an extremely hard target to hit. That is the goal. Not Fort Knox. Not perfect. Just not the easiest target.

Work through this with your leadership team, not with IT alone — with the people who make governance decisions, hiring decisions, vendor decisions, and policy decisions. Because that is where the gap lives.

Governance Foundation

☐	AI Governance Team	<i>Inclusive. C-Suite, department heads, and field staff champions. Feedback loop up and down. Full final authority must be given to this team.</i>
☐	AI Acceptable Use Policy	<i>A written, signed policy that defines which AI tools are approved, what categories of data may be entered into them, and who approves exceptions. Not a one-page memo. Document with teeth.</i>
☐	Approved Tool List	<i>A current list of AI tools that have been reviewed and cleared. Not tools people are using — tools that have been evaluated. Everything else is shadow AI until it appears on this list.</i>
☐	Data Classification Framework	<i>A clear definition of what data is sensitive, what data is internal, and what data must never enter an AI tool — especially a shared-model platform that trains on client contributions. Is that classification explicitly referenced in your AI policy?</i>
☐	Vendor Review Process	<i>Before any AI tool goes on the approved list, someone reads the terms of service and asks the tough questions on data storage, training, etc.</i>
☐	Final Decision Authority Defined	<i>Has your policy defined who the AI final decision makers are — who has the authority to approve, deny, or override an AI tool or use case?</i>
☐	Personal Cell Phone Use Addressed	<i>Has it addressed personal cell phone use with AI — company data entered into AI apps on personal, unmanaged devices?</i>
☐	AI Request / Submission Process	<i>Does it address the process for an employee to submit a desired AI tool for review and decision on approved use?</i>
☐	Public Prompt Sharing Addressed	<i>Does it address or ban publicly sharing prompts, especially ones that reference company data, processes, or decisions?</i>
☐	Zero-Retention, No-Training Requirement	<i>Does it require that any approved AI tool guarantees no LLM training on your prompts and zero data retention, so NDAs and customer agreements are not violated?</i>

Visibility & Control — Must See & Control Data

☐	SOAR / MSiem	<i>A security orchestration automation response gives visibility into what traffic is moving on the network and can act swiftly. It flags anomalies in real time. If nobody is watching the logs, the logs are decorative and the data is gone. Catches threat actors at the moment they break in, not weeks or months later when it rises to a full “breach.”</i>
--------------------------	---------------------	--

☐	MEDR	Managed endpoint detection and response. Stops threats like ransomware at the computer/server level. SOAR catches them, MEDR acts on it and stops them.
☐	ITDR	Identity threat detection and response. This watches credential behavior — who accessed what, when, from where, and whether that pattern matches.
☐	Canary Deception	Enticing deceptive assets planted in the network. When threats attack them, they are caught.
☐	DNS Filtering	Domain Name System filters, intercepts, and restricts web traffic at the foundational “phonebook” level of the internet. In terms of blocking AI leaks, it acts as a primary barrier to prevent employees from sending company data to unauthorized, high-risk generative AI websites and services. Even can help with personal cell phone AI use.

People — High-Risk Layer

☐	BYOD Policy Enforced	Personal devices that access company email, company IP, or company systems are governed by a written policy with enforcement. A personal phone carrying your credentials and network access profile is a company security decision, not an employee convenience decision.
☐	Hiring Verification Updated	Your hiring process includes live in-person or video verification through a channel you initiate; reference calls placed to numbers you find independently, and real-time technical assessments for any role with system access. A ten-out-of-ten resume is now a yellow flag, not a green one.
☐	Executive Profile Reviewed	The public digital footprint of your senior leaders — LinkedIn videos, conference recordings, podcast appearances, keynote recordings — has been assessed. Every recording is raw material for voice cloning and deepfake construction. Know what is out there. Does your voicemail have your voice?
☐	Incident Response Contact List Current	The list of people to call when the screens go dark is current, tested, and in at least three places. The insurer and law enforcement's incident line number — not main office — is known by every person who would need it at 3am.

Practice — Validate & Test

☐	Tabletop Exercise Run	Simulated a real-world ransomware and AI breach scenario with the full incident response team — not just leadership, but floor supervisors, IT, HR, communications. The debrief produced a list of things to fix. Those things were fixed. Schedule the next one (2x per year).
☐	IR Plan Tested	Documented does not mean tested. Run the tabletop and call the resources, isolate the systems, verify remediation before testing again.
☐	AI Output Audited	AI system outputs are reviewed against known-good baselines. Subtly skewed vendor recommendations and competitive-intelligence anomalies are investigated, not attributed to training-data issues and filed away.

Verify — Truth Before Helpfulness

AI generates responses from patterns and can present invented information confidently. In business, that can mean a wrong quote, a misleading report, or a promise you cannot keep. Paste this into your standing instructions, if supported.

The Verification Prompt

AI is a pattern-predictor. When it lacks the next pattern, it often invents ("hallucinates") a wrong response and states it confidently. This prompt reduces that risk.

How to use: Copy the prompt below. Paste into your AI of choice or save it to global instructions / your Voice Profile.

YOUR JOB: Truth before helpfulness.

A wrong answer delivered confidently is worse than no answer.

Follow these seven rules in every response.

1. UNCERTAINTY. If you are not fully certain, say so. Use phrases like "I am not certain, but..." or "Verify this before relying on it." Never state a guess as a fact.
2. SOURCES. Do not invent paper titles, author names, URLs, book titles, or article references. If you cannot name a real, verifiable source, say so.
3. STATISTICS. Flag any number you are not 100 percent confident in. Use "approximately" and tell me to verify the number from a primary source.
4. RECENT EVENTS. Tell me when a topic may have changed since your knowledge cutoff. Do not present outdated information as current.
5. PEOPLE AND QUOTES. Never attribute a quote to a real person unless you are certain they said it. If unsure, say "I cannot confirm this quote is accurate."
6. CODE AND TECHNICAL. Never invent function names, library methods, or API syntax. If unsure a function exists, tell me to verify it in the current documentation.
7. LOGIC GAPS. Do not fill missing context with assumptions. If something is unclear, ask a clarifying question before answering.

THE FLAG RULE.

Every time you state something that falls under any of the seven rules above, mark it inline with [VERIFY] at the end of the sentence. At the end of every response, list every [VERIFY] item as a "Sources to Confirm" checklist so I know exactly what to verify before I use this anywhere.

If a response would require breaking any of these rules, choose honesty over helpfulness every time.

What verification does not cover

The Verification Prompt reduces invention. It does not eliminate it, and it cannot tell you what the model quietly left out. Omission has no warning label. For anything critical, the source document is still the source of truth.

Part Four: Token Management and Anti-Drift

AI gets slower and shallower the longer a chat runs. It drifts. The twentieth prompt in a thread costs far more to process than the first, because the model re-reads everything above it. Long

threads are also where sanitization discipline collapses, because the identifiers you pasted an hour ago are still in context.

Token Management also helps with security and compliance because longer threads drift and risks increase due to hallucination. The longer thread also contains much more evidence and potential sensitive data to get compromised. *A shorter thread reduces the blast radius.*

Methods to Manage Tokens Effectively

Save these to global instructions so they apply without being retyped.

1. NO UNSOLICITED EXPLANATIONS. Do not explain why your output is good. Do not walk me through your reasoning unless I ask. Deliver the output. Stop.
2. NO PADDING. Do not restate my question. Do not open with acknowledgment. Do not close with offers to help further. The response ends when the answer ends.
3. MATCH LENGTH TO THE REQUEST. A one-sentence question gets a short answer. Default to the minimum length that fully answers what I asked. If unsure how detailed I want it, ask before writing, not after.
4. REMIND ME WHEN I AM BURNING TOKENS. If I upload a long document when I need one section, tell me once: "TOKEN NOTE: You uploaded a large file. If you only need [section], paste that section instead." Once per session, not every message.
5. FILE UPLOAD GUIDANCE. Avoid screenshots, images, and PDFs. Use markdown first, then plain text, then docx. Others only when layout matters.
6. ONE TASK PER MESSAGE. Stacking five requests produces five mediocre answers. Send related tasks one at a time. For unrelated tasks, start a new session.
7. LONG SESSIONS DEGRADE. If responses are drifting, start fresh. Carry your key context into the new session. Do not assume the model remembers what happened two hours ago.
8. PROJECTS AND FRESH CHATS. Train a Project with standing instructions. Start a fresh chat every 15 to 20 prompts.

Additional Token Management Tips

Outside of your Global instructions noted above, deploy these tactics during chats.

- TURN OFF CONNECTS NOT USED. Every connector you leave ON gets loaded into every message and you pay for them every time, even when not used.
- THROTTLE YOUR MODEL. Start with your Highest model for complex requests then throttle down when editing and finalizing.
- PARSE LARGE FILES. A 20-page PDF can be say 20,000 tokens. Don't upload it all when you only need Pages 9-11. Copy the text from those pages and save to a TXT or MD file and upload that. It's more like 20-200 tokens.
- **End with "ASK ME QUESTIONS"**. A 500 word prompt can cost 500 tokens. I 1 sentence prompt that ends with "ask me questions as needed before creating anything" creates a multiple choice for you to Click (cost is virtually NO Tokens.)

The security reason to keep threads short

Every sanitized prompt is a small, contained disclosure. A ninety-message thread is a growing pile of them in one place, in one log, for one retention period. Short threads limit blast radius. Starting a fresh chat is a privacy control, not just a performance trick.

Never carry raw confidential business, customer, or employee details into a handoff file. Summarize the work using sanitized information.

Handoff Prompt — after 15 prompts

After 15 back-forths in a single chat, get a summary of it without losing anything important. Paste

“Summarize the transcript inside <summary></summary> tags. Include relevant information in the summary such that this conversation will be continued by a new context window without needing to redo work or be provided with relevant constraints or context. Be sure to preserve: (1) any difficulties or problems that came up, and how they were handled or resolved; (2) any possibilities, options, or approaches that were raised, tried, or set aside, and why; (3) anything that was asked for, decided, agreed, ruled out, or established as a preference, constraint, or boundary — stated exactly; (4) exactly where things stand now — what has been covered, settled, or completed so far; (5) anything still open, unresolved, promised, or expected to happen next; (6) specific details that would be hard to reconstruct — names, numbers, dates, exact wording, links or references — kept exactly. Be complete on these even at the cost of length; keep everything else concise. Weight the two voices differently: keep what the user said, asked for, shared, or established carefully and close to their own words; your own explanations and reasoning can be condensed much further, to what they concluded or produced — as long as nothing in the six items above is dropped.

Create a complete Markdown handoff file from this conversation.”

New Chat Start-Off Prompt

Paste into New Chat Thread:

“Use the attached handoff file as the working record for this matter. First list the objective, the verified facts, open questions, constraints, and the next recommended action. Then wait for my instruction. Do not add facts not supported by the handoff file or any attached source.”

Document Parsing Prompt (before analyzing any Large Doc)

You are reviewing the attached document for [business purpose]. Do not analyze or summarize the entire document. Create a document map in a table with section or page range; topic; key facts; decision relevance to [purpose]; exact quotes worth preserving; whether the section is germane, meaning directly relevant, to the purpose.

CHART and TABLE CREATION PROMPTING

If you are trying to create an image from a data set (a visual chart or table), you will find that may often create an image with errors in the numbers. One Pro Tip is to prompt an AI to Code the HTML Image for you. Then upload that image into a design tool like Canva, Adobe etc

Upload an image sample you like and prompt this:

“Code an HTML infographic like the one I attached, but about (topic) using these numbers (include a CSV or paste numbers you want)”

The text is spelled correctly. Image generators still can't promise that.

AI Privacy Checklist

01 Choose Right Plan Use Enterprise or Sandboxed tool plan for work. Check seat minimums and data policies of vendors-confirm BAA and independent compliance verification.	02 Turn OFF Training & Verify Retention Disable model training and check retention rules of chosen plan since NDAs and customer agreements may be violated.
03 Skip Chat Feedback Avoid thumb up/down on sensitive chats. Feedback may share conversation violating compliance or NDAs or customer agreements.	04 Keep Chats Private Do Not Create Public Share Links for sensitive chats.
05 Use Temp Chat or Incognito For sensitive topics. Safety retention may still apply.	06 Turn Off Memory Disable memory for more privacy. Review/delete old memories.
07 Delete Old Links Prior shared chats can be deleted to avoid future compliance violations.	08 Check Codex Settings Review separate Codex training controls, including full-environment data.
09 Verify Browser Extensions Check who can read chats and where data gets shared.	10 Protect Sensitive Data Keep PHI, legal, financial, client and unreleased IP out of all personal accounts and verify retention rules.

Quick Reference Card

Always

- Sanitize before you type, not after.
- Use only company-approved tools for work. Do not include confidential data unless the tool and use are explicitly authorized. Substitute roles and ranges instead of deleting facts.
- Add Role, Examples, and eXpectations to every real task.
- End prompts with "Ask me questions as needed before answering." Keep the Verification Prompt in global instructions.
- Fresh chat every 15 prompts.

Never

- Names, full dates, Social Security numbers, customer or employee IDs, addresses, phone numbers, or email addresses.
- Confidential audio, face photos, or credentials. In any form.
- The original file when a paragraph will do.
- Give clients copy-paste AI without verification and Human review and editing..
- A document approved or sent without checking it against the original source and what actually happened.

Want to learn more

Ask about our complimentary AI Workshop for leadership, or our complimentary Live Cyber Awareness Training for all employees. Please share this with others.

A sanitized prompt is not a weaker prompt. It is the same question, minus the liability.

Created by David Dean Mauro | NetGainIT.com | CyberCrimeJunkies.com | Moving Target Book Series